Computer Communications 234 (2025) 108091

Contents lists available at ScienceDirect

Computer Communications

journal homepage: www.elsevier.com/locate/comcom

5GMap: Enabling external audits of access security and attach procedures in real-world cellular deployments

Andrea Paci[1], Matteo Chiacchia[*,1], Giuseppe Bianchi

University of Rome "Tor Vergata", Rome, Italy
CNIT Natl. Network Assurance & Monitoring LAB, Rome, Italy

ARTICLE INFO

Keywords:
Mobile networks
4G
5G
Security
Security algorithms
Configurations
Encryption
Privacy
Protocol

ABSTRACT

In cellular networks, security vulnerabilities often arise from misconfigurations and improper implementations of protection mechanisms. Typically, ensuring proper security configurations is the responsibility of network operators. The tool described in this paper, called 5GMap, empowers legitimate subscribers, equipped with software-defined radios (Ettus B210 or X310), with innovative means and methodologies for auditing security configurations of the access networks they are connecting to. Specifically, 5GMap allows to evaluate negotiable ciphers, predictability of temporary identifiers (TMSI), resilience against disclosure of privacy-sensitive identifiers (IMSI, IMEI), and susceptibility to downgrade attacks. 5GMap achieves this by iterating access and attach primitives using either carefully crafted signaling messages requiring specific cryptographic configuration, as well as custom methodologies such as using predictable TMSIs and querying the network with non-standard signaling message sequences to detect potential departures from the expected protocol specification. Extensive testing over four mobile network operators and three virtual network operators reveals significant security and privacy issues: many networks allow unencrypted or even unauthenticated communication, TMSI randomness and IMSI concealment are not consistently ensured across all operators tested, and many other fine-grained concerns emerge among different operators. We believe that our findings highlight the usefulness of tools like 5GMap to assess (and ultimately improve, through responsible disclosure) the security posture of 4G and 5G cellular networks in the wild.

1. Introduction

Over the past four decades, personal communication systems have undergone significant transformations. Smartphones have combined mobile phones and data communication, completely changing how we interact and go about our daily lives. These changes affect everything we do, from socializing to working, making smartphones essential in today's world. As we rely more on these devices, it is crucial to ensure they are secure and protect our privacy. With the rapid increase in digital transactions, sharing of sensitive information, and online communication, it is urgent to address and fix potential security issues.

Research in the field has revealed numerous vulnerabilities in mobile communications, including confidentiality breaches, encryption weaknesses, and protocol gaps that attackers can exploit [1–4]. Although the lack of protection in the first generation of cellular networks and the rudimentary security design of GSM systems were the initial sources of security and privacy issues, modern generations of cellular networks have made systematic improvements. These advancements include the adoption of stronger cryptographic algorithms starting with 3G and the implementation of a comprehensive security architecture in 4G.

Unsurprisingly, with a few notable exceptions such as [5], which exploited a severe design flaw now corrected since Release 15, most recent attacks documented by the research community focus on the implementation or misconfiguration of protection mechanisms within the network architecture and deployments. Often, vulnerable configurations, which might even lead to the disabling of entire security features, stem from risk-based or cost-based decisions. For instance, the deliberate choice by 3GPP to omit integrity protection until the 4G/LTE

* Corresponding author at: University of Rome "Tor Vergata", Rome, Italy.
E-mail addresses: andrea.paci@cnit.it (A. Paci), matteo.chiacchia@uniroma2.it (M. Chiacchia), giuseppe.bianchi@uniroma2.it (G. Bianchi).

[1] Both authors contributed equally to this work.

[2] Page 24 of the ENISA report illustrates an example of vague specifications: [in clause 5.3.9 of the 3GPP security specs TS 33.501], a requirement related to 5G spec.: "The gNB shall support confidentiality, integrity and replay protection on the gNB DU-CU F1-U interface for user plane", and then a note says: "The above requirements allow to have F1-U protected differently (including turning integrity and/or encryption off or on for F1-U) from all other traffic on the CU-DU (e.g. the traffic over F1-C)".

https://doi.org/10.1016/j.comcom.2025.108091
Received 16 June 2024; Received in revised form 10 January 2025; Accepted 1 February 2025
Available online 10 February 2025
0140-3664/© 2025 The Authors. Published by Elsevier B.V. This is an open access article under the CC BY license (http://creativecommons.org/licenses/by/4.0/).

specification was primarily motivated by concerns regarding the additional overhead it would impose on the radio layer. The decision was not reversed until the advent of 5G, potentially influenced by practical attack scenarios [4] that demonstrated how the lack of integrity protection could be effectively exploited in real-world conditions.

Misconfigurations can often arise unexpectedly from various sources, including human errors, misinterpretations of security guidelines, or simply the improper application of 3GPP standard rules, which can sometimes exhibit a significant degree of looseness and optionality. A recent ENISA report thoroughly analyzes and highlights this issue [6].[2]

Misconfigurations become particularly critical when coupled with limited visibility of security configurations, meaning there is no clear way to monitor and confirm the status of the security measures in place. To fulfill this goal, this paper introduces 5GMap, a tool designed to implement an end-user-based active probing methodology to enable users to assess the protection measures in their network connections. 5GMap extends our preliminary work [7], restricted to the configuration of encryption and integrity algorithms, by adding tests to reveal predictability of TMSIs, variations in configurations among operators, differences between attaching with TMSI and IMSI, and the potential for replay or downgrade attacks. Additionally, we evaluated the predictability of radio configuration parameters to prevent replay attacks on the radio interface and ensure compliance with standard procedures. In summary, 5GMap as documented in the remainder of this paper extends beyond configuration assessment for LTE deployments [7], by covering also 5G cells, as described in Section 3, and by including solutions that span three main directions:

- **Security Algorithms Configuration Analysis**: Extensive analysis of encryption and integrity algorithms in 4G and 5G NSA networks, focusing on both Access Stratum and Non-Access Stratum, using different network registrations with and without preexisting context.
- **Potential Privacy Leakage Analysis**: Analysis of predictability and exposure of user-sensitive values that can be used to leak the identity of a user and compromise privacy guarantees. This can be achieved by carefully examining the registration procedure and the evolution of private identifiers (such as TMSI) across multiple registration.
- **Potential Security Issues Analysis**: Review of the radio connection parameter and radio configuration predictability, to ensure protection from passive sniffing and relay attacks, and eventual exposure to Security Downgrade and Message Replay attacks.

The remainder of the paper is organized as follows. After a brief overview in Section 2 of the LTE and 5G connection set-up procedures relevant to the paper, Section 3 outlines the objectives and methodology of 5GMap. Sections 4 and 4.1 elaborate on our design and implementation choices. In Section 5, we discuss our findings and discoveries, with a detailed analysis in Section 6. Related works are examined in Section 7, and our conclusions regarding the various issues encountered are presented in the final Section 8.

2. Background

In this section we provide a background on *4G LTE* and *5G New Radio* architectures (Fig. 1 and Section 2.1), with emphasis on the protocol stack (Section 2.2) and especially on the *Attach Procedure* (Section 2.3), i.e., the procedure responsible to establish a communication.

[2] Page 24 of the ENISA report illustrates an example of vague specifications: [in clause 5.3.9 of the 3GPP security specs TS 33.501], a requirement related to 5G spec.: "The gNB shall support confidentiality, integrity and replay protection on the gNB DU-CU F1-U interface for user plane", and then a note says: "The above requirements allow to have F1-U protected differently (including turning integrity and/or encryption off or on for F1-U) from all other traffic on the CU-DU (e.g. the traffic over F1-C)".

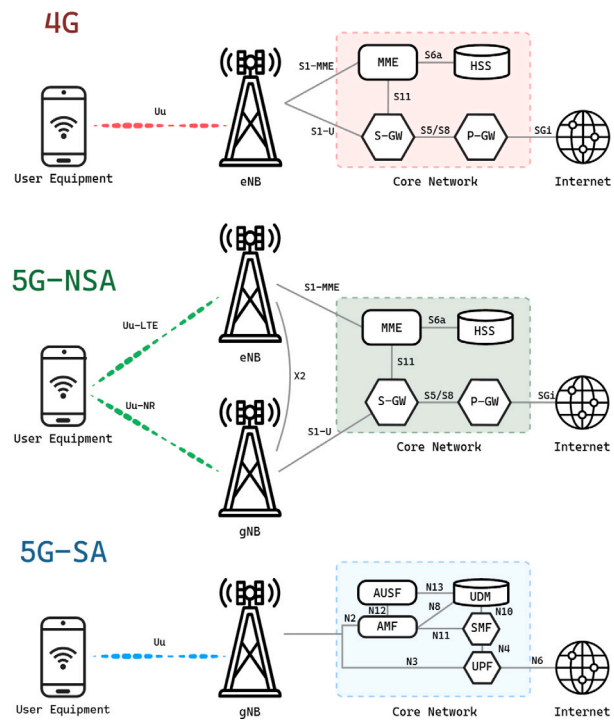

Fig. 1. 4G/5G network architecture.

2.1. 4G & 5G network architectures

Mobile network development adheres to the **3GPP** standards, ensuring global coordination among manufacturers and service providers [8]. Both 4G and 5G networks consist of three main components: the User Equipment (UE), the Base Station (BS) and the Core Network (CN).[3]

User Equipment (UE). The UE is a user device with a Universal Subscriber Identity Module (USIM), containing credentials necessary for mutual Authentication and Key Agreement (AKA). Typical UEs include cell phones, tablets, and IoT devices.

evolved NodeB (eNB)/next-generation NodeB (gNB): In 4G, the eNB is the base station, handling radio connections with UEs and implementing Radio Resource Control (RRC) procedures. The 5G equivalent of the eNB is the gNB.

4G and 5G Core Network: The 4G Core Network (Evolved Packet Core) includes the Home Subscriber Server (HSS) for user authentication, the Packet Data Network Gateway (P-GW) for external IP access, the Serving Gateway (S-GW) for data routing, and the Mobility Management Entity (MME) for user management, two-way authentication, security algorithms, and location tracking. The 5G Core Network is a complete and novel redesign as a SW-based Service-Oriented Architecture. It comprises the Access and Mobility Management Function (AMF) for UE registration and mobility, the Session Management Function (SMF) for session control, the User Plane Function (UPF) for packet forwarding, and the Authentication Server Function (AUSF) for subscriber authentication. Despite different names and deployment models, 4G and 5G Core Network elements share similar functions for seamless operation.

In the transition from 4G to 5G, the so-called 5G Non-Standalone (NSA) mode has been devised to enable the deployment of 5G New

[3] Although the transition from 4G to 5G networks introduces numerous benefits, it does not affect the primary features relevant to this study. Therefore, we describe both 4G and 5G networks without differentiating their protocol behavior.

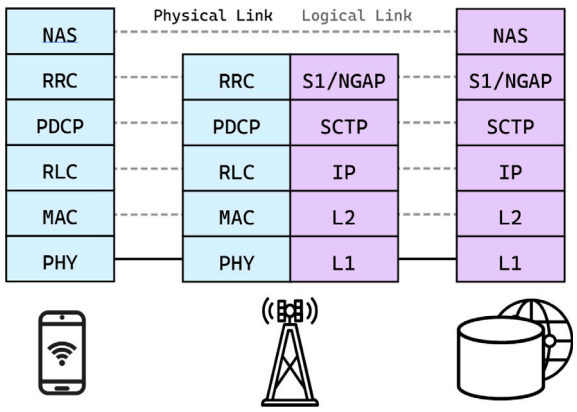

Fig. 2. 4G/5G network stack.

Radio (NR) access, using existing 4G Core Network infrastructure. The eNB directs the UE to the appropriate gNB, ensuring integration with the 4G Core Network. In a 5G NSA scenario, the whole control protocol still relies on 4G standard. The difference between a 4G Network and a 5G NSA Network is the usage of *Dual Carrier*: while all the control plane messages are routed towards the 4G Base Station (eNB), the data plane messages are instead routed towards the 5G Base Station (gNB) in order to benefit from the performance upgrade of the 5G radio communication. All the logic involved in the mobile communication between the user and the network still relies on 4G Core Network.

2.2. Protocol stack

LTE and 5G technologies utilize a complex protocol stack (Fig. 2) to govern data transmission between mobile devices and network infrastructures. Security and radio configuration parameters primarily affect the upper layers, as follows.

The **Non-Access Stratum (NAS)** facilitates communication between the UE and the Core Network, managing UE mobility, session handling, user identification, authentication, and security control through the Authentication and Key Agreement (AKA) protocol. It also updates the UE's tracking area, handles network-initiated paging, and assigns temporary network identifiers (TMSIs) and IP addresses. NAS provides mandatory integrity protection and optional encryption for signaling messages [9,10].

The **Radio Resource Control (RRC)** manages radio session and bearer control, including session initiation, maintenance, and termination. It handles UE radio measurements, Access Stratum session key agreements, transparent transmission of NAS messages and other relevant functions [11]. Notably, while RRC messages are encrypted and integrity protected, messages exchanged before AS security activation are transmitted without any protection mechanisms.

The **Packet Data Convergence Protocol (PDCP)** enforces Access Stratum (AS) security functions, providing encryption and integrity protection for control and data plane messages. It also enhances data rate efficiency through Robust Header Compression and streamlines Handover procedures [12].

Moving down the stack, the **Radio Link Control (RLC)** segments and reassembles packets, oversees retransmission and provides different *transmission modes* (Transparent, Acknowledged, and Unacknowledged modes) [13].

The **Medium Access Control (MAC)** layer coordinates radio resource access, channel multiplexing, and ensures reliability through identifiers (RNTI) obtained via the Random Access Procedure [14].

Finally, on the air interface, the **Physical layer** manages radio signals for stable UE to eNB/gNB communication. The three lower layers (RLC, MAC, PHY), which handle radio signals and resource management, are not primarily relevant for security configuration.

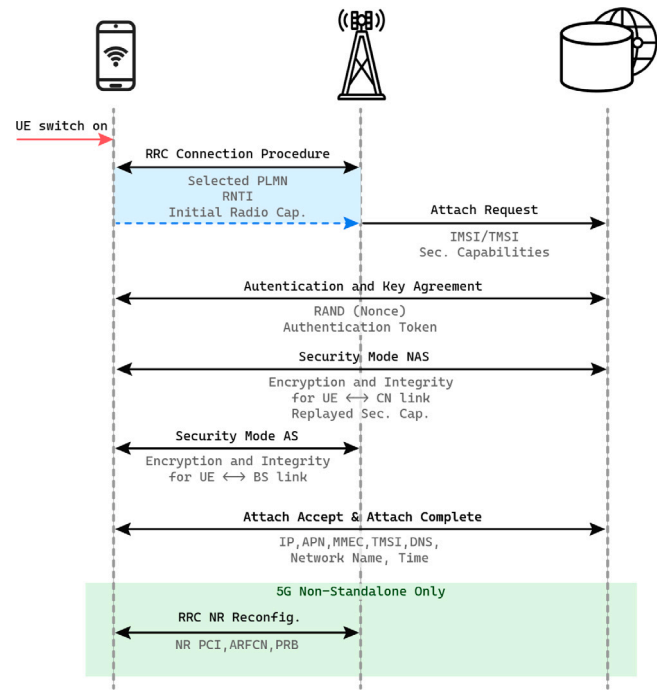

Fig. 3. 4G/5G attach procedure.

2.3. Security procedures

The security of mobile networks relies on multiple mechanisms[4] to ensure confidentiality and authenticity to its end users. Among these mechanisms there are Mutual Authentication, Anti-Replay protection, Public Key Infrastructure and Encryption/Integrity. All of these mechanisms must function correctly, as even if one of them fails, the entire security of the system is compromised.

Once an RRC Connection is established between the UE and the Base Station, the user initiates the *Attach Procedure* (as seen in Fig. 3) by communicating with the Core Network, specifically with the MME, through the exchange of control messages. Within the "Attach Request" message, the UE identifies itself by transmitting either the **IMSI** or the **TMSI**. The TMSI is a regularly updated temporary identifier used to protect user privacy by avoiding the transmission of the permanent IMSI over the air interface whenever possible. The Attach Request message additionally includes its **UE Capabilities**, comprising the encryption/integrity algorithms supported by the user device connecting to the network along with other radio access parameters. Subsequently, the **AKA** process is invoked, enabling mutual authentication and ensuring that the user is connecting to a legitimate Base Station/Core Network: The *MME* dispatches an *Authentication Request* containing a random *nonce* and an *authentication token*. The UE verifies the authentication token, computes the *RES*, and encapsulates it within the *Authentication Response*, which is then validated by the network.

To activate security mechanisms, the Core Network sends the **NAS Security Mode Command**, which is integrity protected. This command specifies the chosen security algorithms for NAS layer messages and includes a replay of the original *UE Security Capabilities* to prevent algorithm downgrade attacks [3]. The UE responds with a *Security Mode Complete* message. Similarly, the *eNB* (or *gNB*) sends an ***RRC Security Mode Command*** to the UE, specifying the encryption and

[4] Since our tests cover both 4G and 5G NSA (Non-Standalone) networks, we will use 4G Core Network terminology, as 5G NSA networks rely on LTE core infrastructure.

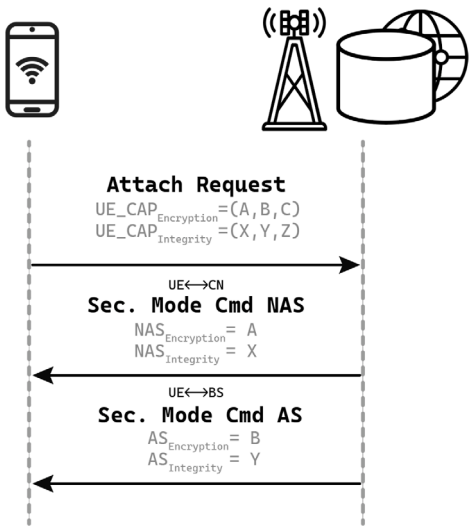

Fig. 4. 4G/5G security establishment.

Table 1
Mobile security algorithms.

Algorithm	Type
EEA0/NEA0 EIA0/NIA0	Null
128-EEA1/NEA1 128-EIA1/NIA1	Snow3G
128-EEA2/NEA2 128-EIA2/NIA2	AES
128-EEA3/NEA3 128-EIA3/NIA3	ZUC

integrity algorithms for the Access Stratum,[5] and awaits an *RRC Security Mode Complete* message from the UE. Finally, the network assigns an IP address to the UE in the Attach Accept message, and the UE confirms this with an Attach Complete message, completing the connection establishment process. The security establishment process is shown in Fig. 4.

If the network and the subscriber are **5G enabled**, an extra message is sent after the Attach Accept, which is a **RRC New Radio Reconfiguration**. This message contains the "radio coordinates" for the UE to connect to the New Radio Base Station (gNB). The UE responds with a **RRC NR Reconfiguration Complete**.

LTE and 5G networks offer a variety of encryption and integrity protection algorithms [15], known as EPS Encryption Algorithm (EEA) and EPS Integrity Algorithm (EIA) for LTE, and NR Encryption Algorithm (NEA) and NR Integrity Algorithm (NIA) for 5G. The most commonly used and widely supported algorithms are summarized in Table 1. The "null" algorithms, EIA0/NIA0 and EEA0/NEA0, are used for no integrity and no encryption respectively. While ensuring the integrity of the signaling plane is compulsory during normal operation, encryption remains optional but highly recommended [15]. Regarding the *integrity* on the *data plane*, while a 4G link has no support for integrity on Data Radio Bearers, the *5G standard* includes and highly recommends the use of integrity also on the data plane.

2.4. Radio configuration

During a typical registration procedure, the UE is instructed on which radio configuration to use on the different Signaling Radio Bearer (SRB) and Data Radio Bearer (DRB). This configuration is achieved upon receiving the **RRC Connection Setup** (before the Attach Request) and **RRC Reconfiguration** messages. To avoid redundant information, channel (re-)configuration is done incrementally: if one or more parameters should not be changed, their values are not included in the radio configuration message (i.e. only variation are exchanged). Although radio configuration predictability is not a major security concern, maintaining anonymity is crucial. If not upheld, attackers could passively sniff Over-The-Air traffic, differentiate between users, and potentially launch Man-in-the-Middle attacks by predicting traffic structure and timing.

The messages that handle the UE radio configuration are the **RRC Connection Setup** and the **RRC Reconfiguration**. The former is a Downlink message sent over the air unprotected, which provides the UE with a basic radio configuration for the *SRB 1* during the initial registration phase. The RRC Reconfiguration message establishes more advanced radio features (like Measuring Cell, Channel Quality Indicator (CQI) Report, and Sounding Reference Signal (SRS)) and configures the *SRB 2* and the *DRB*. This message is sent after the security configuration is set up and is protected by encryption and integrity. While the UE is connected, multiple RRC Reconfiguration messages can be sent to modify the radio configuration on demand, usually to update the Measurement Cells.

An important parameter present in both RRC Setup and RRC Reconfiguration messages is the **Scheduling Request Index (SRI)**: the SRI determines the "frequency" and "time slot" coordinates in which the UE can ask the network for Uplink resources. This value is essential for determine where and when the UE sends data (Uplink direction). The SRI is sent in the RRC Setup, sent in plaintext, and subsequently should be updated in the RRC Reconfiguration, sent encrypted. The knowledge of this parameter may lead to a tracking of the UL data of a specific user.

3. Approach

5GMap is designed to empower tech-savvy users, equipped with a Software-Defined Radio,[6] with a comprehensive tool devised to explore and analyze cellular network configurations. Its capabilities can be classified into three main areas:

- **Security Algorithms Configuration analysis**: by manipulating requested user device security settings during connection setup and analyzing network responses, 5GMap audits the encryption and integrity protection algorithms set by providers. The tool has been extended from its preliminary version [7] to cover more scenarios, such as attach procedures with pre-existing contexts (e.g., TMSI) and 5G NSA configurations.
- **Potential privacy leakage analysis**: our tool permits to assess predictability of user identifiers (i.e. TMSI, IP address, etc.), and verify whether the network handles sensitive data, such as IMSI and IMEI, during the attach procedure, in compliance with 3GPP standards.
- **Potential security issues analysis**: we have extended the tool to further assess the predictability of certain radio configurations that could lead to passive sniffing, active relay attacks, downgrade attacks and Sequence Number replay attacks.

The tool is engineered also to gain detailed insights into many other facets of the cellular network's operation and configuration (Protocol compliance, IP Assignment, DNS, etc...).

[5] Access Stratum and Non Access Stratum protocols are independent and can use different cryptographic algorithms.

[6] an ongoing open challenge is how to re-design 5Gmap so as to run it on commodity smartphones

3.1. Methodology

At a very high level, 5GMap combines two functionalities: i) a module devised to generate and manipulate security/privacy-critical 4G/5G signaling messages and relevant parameters and ii) a function devised to interact with the network by adaptively sending suitable sequences of crafted messages and analyze the relevant responses. in terms of message spoofing, 5GMap specifically covers the two layers mostly involved in authentication and security configuration, namely:

- *RRC Messages*: These messages play a vital role in setting up communication with the Base Station. By examining RRC messages, we can identify the security algorithms that the BS supports and those that are ultimately selected for communication. Furthermore, by analyzing these messages, we can examine all the radio parameters both before and after the establishment of the various communication channels.
- *NAS Messages*: These messages are essential for the interaction between the UE and the Core Network. By analyzing NAS messages, we can ascertain which security algorithms the Core Network supports and which ones are favored during the security negotiation process. These messages also provide additional information, such as the IP address and TMSI allocated to the user by the network, along with MME/AMF codes for network clustering and various other details crucial for the ongoing configuration assessment.

More specifically, during the algorithm negotiation phase of the attach procedure, the UE reports its supported algorithms in the Attach Request message. The Base Station and Core Network then select one encryption algorithm and one integrity algorithm from the UE's list based on their configuration. For example, if the Base Station is configured to provide AES for integrity, but also supports the "null" integrity algorithm, the goal is to see if we can force the use of the "null" integrity algorithm. By establishing multiple connections with different security capabilities and monitoring the responses from the Base Station and Core Network, we thus achieve a complete mapping of all supported algorithms. A schematic representation of this process is shown in Fig. 5.

Additionally, we test the feasibility of establishing insecure communication by not using any security algorithms to observe network behavior. To do this, we retrieve the Security Mode Commands from both the RRC and NAS messages and analyze the algorithms provided by the network. Our latest 5GMap version, documented in this paper, supports additional iterations for 5G Non-Stand Alone assessment, as well as the TMSI Attach Procedure to determine if behavior differs in these scenarios. This allows us to conduct a *configuration assessment* in both independent scenarios (IMSI attach) and dependent scenarios (TMSI attach).

4. Implementation

In the following chapter, we will explore the implementation choices, providing a detailed insight into the decisions made.

4.1. Design

The investigation of the security mechanism implemented in mobile networks, while it can be done "passively" by just analyzing the messages exchanged between the mobile phone and network, requires some extra functionalities to truly assess what the network offers in term of security. Some variation to what messages are exchanged and the respective data contained in those messages is necessary. Given this consideration, we aim to develop a tool that is capable of message injection possibilities and standard procedure mutation. The firmware of standard mobile phones (Commercial-off-the-shelf) does not allow easily the modification or injection of messages, even if there are reports of modified firmwares that allow a basic injection of custom

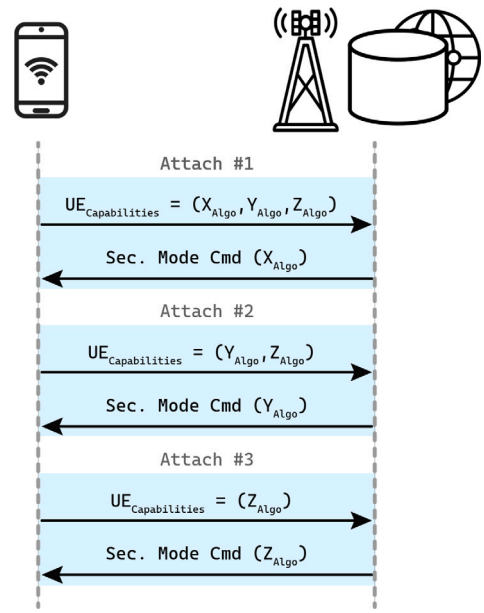

Fig. 5. 5GMap methodology.

messages [16,17]. Our task cannot be achieved with a COTS phone, so we necessitate the use of a customizable UE (User Equipment) to conduct our tests. This limitation in the firmware restricts our ability to alter and analyze the PDCP, RRC and NAS messages. By utilizing a customizable UE we are capable to trigger specific interaction with the network under test.

To establish the radio connection with a real Base Station, the setup involved the use the following equipment:

- **Software Defined Radio USRP B210 or X310**: A type of Software Defined Radio (SDR) that provides a flexible platform for designing, prototyping and deploying wireless communication systems. It is capable of transmitting and receiving a wide range of radio signals, making it suitable for various applications [18].
- **SIM Card Reader with real SIM**: Security algorithms are transmitted within the Security Mode Command, which comes after the *authentication phase*. Therefore, to access these algorithms and retrieve them it is necessary to pass the authentication phase as a legitimate user [19].
- **Workstation Laptop**: Signal processing and protocol implementation is done on a off-the-shelf computer. The decoding/encoding of the radio spectrum can be a demanding operation with general purpose hardware. To compensate such limit, a laptop with adequate performance is required. Along with it, a proper tuning of the OS helps to ensure the processing stays within the time window allowed for resource block processing. For protocol implementation of both 4G and 5G we use *srsUE*, one of the tool offered by the srsRAN software suite [20],[7] to impersonate the UE and retrieve the data of interest. srsUE implements all the protocols and procedures that compose a proper User Equipment, in both 4G and 5G technologies.

In order to achieve our goals, srsRAN inner logic have to be significantly modified in order to both properly connect to commercial networks and to achieve the desired mutations in both the logical

[7] The srsRAN software suite is an open-source collection of 4G and 5G software radio implementations from SRS. srsRAN is designed to serve as a development framework for researching and implementing software-based radio solutions in mobile communication networks.

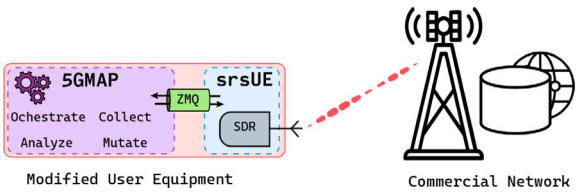

Fig. 6. 5GMap architecture.

flow of the procedure and the contents of the exchanged messages. A summary of the design can be seen in Fig. 6.

4.2. Hook

In order to force specific behaviors and retrieve the desired information sent from the Base Station, we properly modified the source code of *srsRAN* and added code snippets, known as "*hooks*", that enable the extraction and the injection of exchanged messages between the UE and the BS. Through these hooks, messages exchanged in regular mobile communication are directed toward 5GMap by establishing a communication bridge with srsUE.

After a careful study of 4G and 5G protocols, it was made the decision to insert the hooks at the following points:

- The MIB, carried by the PBCH (Physical Broadcast Channel), is managed through the handle present in the dedicated control flow for this channel. The hook is inserted into this handle, specifically after the process of decoding the data contained in the packet.
- SIB1, SIB2, and SIB3 are RRC messages, The hooks were inserted into the functions that individually handled each SIBs.
- To retrieve RRC messages, it was made the decision insert the hook at the PDCP level as this layer acts as a connection point for all upper layers.
- Each NAS message is associated with its dedicated handler, and therefore the hooks are inserted within these specific handlers.

For the last two types of messages (RRC and NAS) hooks, they have to be inserted at two distinct points, one for *Uplink* messages and one for *Downlink* messages and the decoding phase is done in 5GMap directly.

To establish a communication channel between the hook and the 5GMap module, the ZMQ library [21] has been employed, implementing an inter-process ordered Request-Reply pattern.

4.3. 5GMap module

5GMap amplifies capability to comprehensively extract all desired configuration parameters, enabling a concentrated focus on both the security and radio aspects of analysis. In the radio domain, this tool delves deeper into revealing the predictability levels of parameter values. Conversely, in terms of security, it becomes even more critical to examine if encryption and integrity specifications are adhered to, thereby emphasizing the significance of such analysis.

5GMap is a versatile tool designed for conducting diverse tests, equipped with a variety of features. Given that each Attach request can be directed to a different MME by an eNB, 5GMap logs the specific MME to which each request was directed, simplifying the correlation of test outcomes with distinct entities. Additionally, it offers advanced orchestration capabilities, automatically retrying tests in case of failure due to software or SDR issues.

The tool provides advanced capabilities for parsing, decoding, and extracting critical fields from RRC/NAS messages. It leverages decryption keys to facilitate these operations and supports structure-agnostic JSON parsing [22], ensuring flexibility regardless of the message format. It manages security configuration changes of the UE and handles NSA attaches through message injection, addressing the limitations of "srsUE" in configuring NR capabilities upstream.

Additionally, 5GMap presents the final output in a clear and organized manner, saving it to a file for easy reference. The tool supports advanced logging for comprehensive insights and saves "pcap" files, including RRC and NAS keys, for later consultation with the *Wireshark* software.

4.4. srsUE modification

During our first experiments, we observed that to fully complete the registration procedure, some tweaks had to be made in order to fully comply with what the networks expects.

In particular, we modified in the original source code the following details:

Establishment Cause: Commercial networks often limit UE registration types to "Emergency" and "Signaling". We had to force *srsUE* to register using the "Signaling" establishment cause to successfully connect to the network.

Random Access "Random Value": We investigated whether the "Random Value" provided by the UE during the Random Access Contention Resolution phase served as a "seed" for subsequent cryptographic procedures, standardizing the Random Value across all registration procedures.

Correct Context save: srsUE does not handle UE context saving properly, which includes TMSI, encryption/integrity key, and sequence number. srsUE has been modified to correctly save the context in order to be used to make subsequent registration with the TMSI and other pre-established parameters.

Context reset between registration procedures: while normal UEs typically stores some "context" information in order to speed up subsequent registration. When a UE register to a network with a preexisting context, some steps of the registration procedure are skipped since they are not required (i.e. the Authentication and Key Agreement). Some test cases require that the whole Attach Procedure is done in full, so it is required that the context is reset after each registration attempt.

UE Radio Capabilities, Category and FeatureSet: some networks "blacklist" specific UE to access certain features (like NR link in 5G NSA, Handover, Dual Carrier, etc.) based on a series of parameters that describe what the UE is capable to achieve (i.e. MIMO, Header Compression, support for multiple Measurement Cell). In order to mimic as closely as possible the behavior of the network with commercial UEs, UE Radio Capabilities, Category and FeatureSet[8] have been taken from a COTS UE and used during the registration with srsUE.

Fake Measurement Reports for 5G NSA: even if not stated in the standard, the network may not give the UE the NR configuration (and the relative parameters to allow a Random Access to the NR Base Station) until the UE does not inform the network that the 5G station is reachable and the received power is within the accepted ranges. Since in our work we are not interested in achieving a full 5G NSA connection but just the parameters of the NR link, the UE has been modified to send "Fake" measurement report to the network stating an excellent signal between the UE and the gNB.[9]

Avoid reset of NAS Security Context: in some instances, we observed that the networks may send a NAS PDU without any protection (i.e. without encryption and integrity) even after the establishment of

[8] UE Radio Capabilities, Category, and FeatureSet parameters define the capabilities of a User Equipment. UE Radio Capabilities encompass radio-related features such as supported bands and modulation schemes. Category denotes a numerical value indicating MIMO capability and maximum bandwidth support. FeatureSet is a bitmask detailing processing capabilities such as handover from 4G to 2G, support for measurement reporting events, etc.

[9] When in a 5G NSA scenario, the security of the data plane and radio configuration of the NR link is shared using a *RRC Reconfiguration* message sent on the LTE link.

the Security Context. The standard states that upon reception of such messages, the UE may drop the existing Security Context. While srsUE implements this clause correctly [23], commercial networks and UEs seems to be more "elastic" and may occasionally send specific messages unprotected and avoid the drop of Security Context. This behavior is not compatible with srsUE because it would result in having the subsequent messages unprotected and thus resulting in the abortion of the connection. As a consequence, srsUE has been modified to handle such behavior similarly to what COTS UEs do.

Sequence Number manipulation and tolerance: in order to assess if it is possible to achieve Replay Attacks on commercial networks, srsUE has been modified to allow the use of arbitrary Sequence Number at the PDCP layer for both transmitted and received PDUs.

The modification listed above are only possible if using a "programmable" UE. With a COTS UE, we would not have the possibility to achieve such fine-grain control.

5. Experiments conducted & results

5.1. Experimental setup

Once the setup outlined in Section 4.1 has been completed, we developed a process to successfully establish a radio connection to a real network.

Given that our experiments took place in an authentic operational environment, as opposed to a controlled laboratory setup, we paid careful attention to each aspect to mitigate any potential connection failures ensure that our experiments yielded compliant results.

This procedure consists of the following phases:

1. *Verification of available frequencies*: Network Signal Guru [24] is used on an Android device to check frequencies of the available cells of the chosen network operator in the area. From the list, the EARFCN (E-UTRA Absolute Radio Frequency Channel Number) that returns the highest Signal-to-Noise Ratio (SNR) value is selected.
2. *Signal quality verification*: To assess the actual quality of the signal received by the SDR, various operations are performed. Firstly, the "*uhd_fft*" command, part of the GNU Radio suite [25], is executed to manually evaluate the spectrogram of the received signal. Subsequently, "*cell_search*" and "*pdsch_ue*" executables, part of the srsRAN example scripts, are executed. The former is used to determine whether the SDR can detect cell and synchronize with it, while the latter, among other factors, reports the Block Error Rate (BLER) of the received signal.
3. *Setup of the proper User configuration*: The srsUE configuration file is properly modified to reflect the cell configuration parameters gathered in the previous steps: EARFCN, Access Point Name (APN), TX/RX gains and PSS/SSS values to ensure the tests are made on a specific cell. Other required changes include updating Radio Frontend driver to enable the connection with the USRP B210 or X310, setting the "USIM mode" to "pcsc" in order to enable the usage of the SIM Reader with the legitimate SIM of the chosen network operator [19]. Finally, we tuned SDR parameters to maximize device performance and ensure optimal reception and transmission of radio signals.
4. *Execution of 5GMap and data collection*: Once all the steps before are correctly carried out, 5GMap is executed. After 5GMap has finished all its iteration, it shows a summary of the results.

Since 5GMap only needs the exchange of a few messages to gather all the information it requires, it is not necessary to ensure a high throughput and a highly reliable connection. Typically, such reliability and performance are achieved with features like MIMO (Multiple Input Multiple Output) and Automatic Gain Control. However, these features can also introduce instability into the srsRAN software. To mitigate this issue and create a more stable environment, we have disabled these features by lowering the *UE Category*. This adjustment ensures that 5GMap operates efficiently without the need for the enhanced capabilities that MIMO and Automatic Gain Control provide.

5.2. Experiments performed

We performed experiments on real network deployments in our city (Rome, Italy) using 5GMap. We specifically audited seven operators in total: four **Mobile Network Operators (MNO)** and three **Mobile Virtual Network Operators (MVNO)**.[10] Overall, the experiments accounted to 256 successful registration to the various network. To further validate our results, we conducted our experiments in two distinct zones of the city.

As introduced in Section 3, the functionalities of 5GMap can extract a significant amount of information about the tested mobile network, such as:

Security Algorithms Configuration analysis: the *encryption* and *integrity* algorithms *supported* and automatically selected by *default* by base stations and core networks of the operators under examination in both 4G and 5G connections.

Potential privacy leakage analysis: how the *reallocation of TMSIs, IPs etc.* are managed in various scenarios; the *network compliance* to certain security principles; *IMSI* and/or *IMEI Disclosure*.

Potential security issues analysis: how *radio parameters change* during a single connection and among multiple connection and if they are *predictable* (Differences in radio configuration between RRC Setup and RRC Reconfiguration);

differences among radio configuration exchanged by different cells; how erroneous *sequence number is handled* in the data plane; whether the network is *susceptible to capabilities downgrade attacks* and the presence of *Ex-post authentication of UE Security Capabilities*..

Based on our comprehensive testing, we have uncovered significant issues that highlight notable variations among operators. In our findings, we have identified several substantial characteristics, each attributed to specific operators. In the subsequent sections, we will meticulously list the encountered problems, providing detailed insights into the operators affected by each issue for every key aspect.

5.2.1. Security algorithms configuration analysis

Encryption and Integrity algorithms are the primary features that ensure user confidentiality. As a consequence, the security algorithms supported by the network play a key role in the assessment of which security measure a user may expect when connecting to a mobile network. Some of the test have been conducted in two different scenarios: without previous context (i.e. a fresh registration with IMSI) and with previous context existing (i.e. registration with previous security parameters established and with TMSI). Through this analysis, we were able to create a comprehensive mapping of the algorithms supported and chosen by default by operators, with the results shown in Tables 2–4.

Adding to which algorithms are supported, we observed the following behavior in LTE:

Connection with EEA0 ("Null" Encryption Algorithm):

- *Connection with IMSI*: MNO3, MNO4 and MVNO2 allow connection (at both AS and NAS layers) with "Null" encryption algorithm when the attach is made using IMSI.

[10] Mobile Network Operators (MNOs) own and manage their network infrastructure, including cell towers and frequency spectrum, giving them full control over services and technologies. Mobile Virtual Network Operators (MVNOs) lease network capacity from MNOs, using their infrastructure and spectrum, allowing them to offer customized services without having to invest in their own infrastructure [26].

Table 2
AS supported algorithms (Attach with IMSI).

	Algo.	MNO1	MNO2	MNO3	MNO4	MVNO1	MVNO2	MVNO3
eNB Cipher. Algo.	EEA0			✓	✓		✓	
	EEA1	✔	✓	✓	✔	✓	✔	✔
	EEA2	✓	✔	✔	✓	✔	✓	✓
	EEA3							
eNB Integ. Algo.	EIA0							
	EIA1	✔	✓	✓	✓	✓	✓	✔
	EIA2	✓	✔	✔	✔	✔	✔	✓
	EIA3							
gNB Cipher. Algo.	NEA0			✓			*	
	NEA1	✔	✓	✓	✓	✓	*	✔
	NEA2	✓	✔	✔	✔	✔	*	✓
	NEA3						*	
gNB Integ. Algo.	NIA0	✔		✔	✔		*	✔
	NIA1		✓			✓	*	
	NIA2		✔			✔	*	
	NIA3						*	

Supported ✓, Default ✔, * 5G not available.

Table 3
AS supported algorithms (Attach with TMSI).

	Algo.	MNO1	MNO2	MNO3	MNO4	MVNO1	MVNO2	MVNO3
eNB Cipher. Algo.	EEA0	✓	✓	✓	✓	✓	✓	✓
	EEA1	✔	✓	✓	✔	✓	✔	✔
	EEA2	✓	✔	✔	✓	✔	✓	✓
	EEA3		✓			✓		
eNB Integ. Algo.	EIA0	✓	✓		✓	✓	✓	✓
	EIA1	✔	✓	✓	✓	✓	✓	✔
	EIA2	✓	✔	✔	✔	✔	✔	✓
	EIA3		✓			✓		
gNB Cipher. Algo.	NEA0	✓	✓	✓	✓	✓	*	✓
	NEA1	✔	✓	✓	✓	✓	*	✔
	NEA2	✓	✔	✔	✔	✔	*	✓
	NEA3						*	
gNB Integ. Algo.	NIA0	✔		✔	✔		*	✔
	NIA1		✓			✓	*	
	NIA2		✔			✔	*	
	NIA3						*	

Supported ✓, Default ✔, * 5G not available.

Table 4
NAS supported algorithms.

	Algo.	MNO1	MNO2	MNO3	MNO4	MVNO1	MVNO2	MVNO3
EPC Cipher. Algo.	EEA0			✔	✔		✔	
	EEA1	✓	✔			✔		✓
	EEA2	✔	✓		✓	✓		✔
	EEA3							
EPC Integ. Algo.	EIA0							
	EIA1	✓	✓	✔	✓	✓	✓	✓
	EIA2	✔	✔	✓	✔	✔	✔	✔
	EIA3							

Supported ✓, Default ✔

- *Connection with TMSI*: All operators, at the AS layer, allow connection establishment using the "Null" encryption algorithm when the attach is made using TMSI.

Connection with EIA0 ("Null" Integrity Algorithm):

- *Connection with IMSI*: No operator allows connection with "Null" integrity algorithm when the attach is made using IMSI.
- *Connection with TMSI*: All operators, except MNO3, allow connection establishment, at the AS layer, using the "Null" integrity algorithm when the attach is made using TMSI.

Unsupported Encryption causes plaintext communication (for both AS and NAS layer):

- When connecting to MNO3, MNO4, and MVNO2, if the UE advertises support only for an encryption scheme unsupported by Network side (e.g. EEA3), the network disregards the UE's security capabilities and proceeds without encryption.

Connection, at AS layer, with EEA0 and EIA0:

- When the attach is performed with TMSI, all operators except MNO3, allow the establishment of a communication with "Null" encryption and "Null" integrity simultaneously, thus opening a communication with an extremely insecure radio channel.

"Null" encryption as default for NAS layer:

- MNO3 appears to lack support for any encryption algorithm on the NAS layer. As a result, "Null" encryption is the only possible option.
- MNO4 and MVNO2, on some MMEs, choose "Null" encryption by default on the NAS layer.

Null integrity algorithm leads to the usage of "Null" encryption

- MNO2 and MVNO1, during an attach procedure with the TMSI, establish a radio communication channel at the AS layer without

Table 5
Privacy leakage results.

Operator	TMSI Predictable	TMSI Not Changed	IMSI in Plaintext	IMEI in Plaintext	Same MME, Same IP
MNO1	✓		✓	✓	
MNO2	✓		✓	✓	
MNO3		✓		✓	
MNO4	✓		✓	✓	
MVNO1	✓		✓		✓
MVNO2	✓				
MVNO3	✓		✓	✓	

integrity or encryption if the UE specifies only the "Null" integrity algorithm while listing all encryption algorithms (i.e., EEA0, EEA1, EEA2). This happens even though a 'non-null' encryption algorithm could have been selected.

As for the NR link in 5G NSA connection we observed the following:

NR data channel without integrity by default (NIA0 as the only possible algorithm):

- In 5G NSA scenarios, MNO1, MNO3, MNO4, and MVNO3 establish a NR link for data plane without integrity by default.

NR data channel without encryption:

- *Connection with IMSI*: MNO3 allows opening an unencrypted 5G NSA data channel, enabling a potential attacker to sniff the data traffic in plaintext.
- *Connection with TMSI*: All operators allow opening an unencrypted 5G NSA data channel when the attach is made using TMSI.

NR Security Capabilities are not used

- During the attach procedure in 5G NSA networks, a specific behavior has been identified across all MNOs and MVNOs: although the UE provides two separate security capability sets, one for LTE and one for NR, the network selects encryption and integrity algorithms exclusively based on the LTE security capability set. As a result, the NR Security Capabilities included in the attach request are ignored by the network.

As [27] states, while encryption should be supported but it is not mandatory, integrity shall be used on both RRC and NAS signaling. The operators that allow NULL integrity for RRC signaling are indeed not compliant to the standard.

A specificity in security parameters exchange procedure was found: for operators that solely support NIA0, the issue is not merely about declaring support for NIA0. In fact, the integrity algorithm is not communicated at all, leaving the integrity algorithm field empty and without specifying which algorithm should be used in communication, consequently resulting in the absence of integrity usage.

All supported and default algorithms of the tested operators are represented in Tables 2, 3, 4.

5.2.2. Potential privacy leakage analysis

Beside the configuration of supported encryption and integrity algorithm, there are other features that ensure confidentiality for the end user. There are many features that contribute to the security of mobile communications: Mutual Authentication, User identification (IMSI) privacy, correct implementation of cryptography functions, etc.; and each one of them has to properly function in order to avoid the compromise of the whole system. Because of the importance of this other aspect, we delved in assessing if some of these features were implemented correctly.

Through the analysis of the variability of various identifiers and network requests, we obtained the following informations:

Predictable TMSIs:

- *Connection with IMSI*: No operator returns a TMSI that is easily predictable when the attach is made using the IMSI. However, MNO1, MNO4, MVNO1, MVNO2, and MVNO3 have the first 7 digits out of 10 the same during sequential attach procedures.
- *Connection with TMSI*: TMSIs are returned almost sequentially by all operators except MNO3 (refer to the next item for further details) when the attach is made using TMSI. It has been observed that these operators assign the UE a new TMSI with the first 8 or 9 digits out of 10 that are equal to the previous TMSI.

TMSI not changed into different attachments

- MNO3 is the only operator that does not update the TMSI in different attachments, increasing the risk of user tracking.

Network asks IMSI using an unprotected channel:

- MNO1, MNO2, MNO4, MVNO1, and MVNO3 networks, during the attach procedure, ask the user to send their IMSI using an unprotected channel with an Identity Request message before Security activation, facilitating malicious user tracking. Asking the IMSI, and more importantly, asking it using an unencrypted channel is a serious privacy violation. When registering with a valid TMSI, the key to exchange ciphered message is already established. As a matter of fact, beside the possible exchange regarding the IMSI, the other messages are sent using the already established secure channel (in other words, the TMSI was sufficient to establish a secure channel, and as a consequence, to identify the user). The reason why this situation is present (and that even COTS UE allow this non-standard behavior) is unknown.

Network asks IMEI using an unprotected channel:

- MNO1, MNO2, MNO3, MNO4 and MVNO3 networks, during the attach procedure, ask the user to send their IMEI using an unprotected channel, facilitating malicious user tracking like the previous item (IMSI). Even if the IMEI identifies the device rather than the operator subscriber, in typical scenario (one mobile device per user), an IMEI can be used similarly to an IMSI for tracking a user.

Same MME allocate the same IP to the UE

- When a UE connects to the network of MVNO1, the MME assigns it an IP address. If the same UE reconnects to the network and the connection is managed by the same MME, the MME will assign the same IP address to the device. This behavior is not followed by other operators, who always vary the allocated IP address for the user from a /16 subnet.

A summary of this result can be seen in Table 5.

Regarding TMSI Predictability and IMSI Plain-text disclosure, the standard [28] states that the TMSIs should be unpredictable and that IMSI should be asked solely when user identity cannot be derived by the corresponding TMSI. The operators affected by this issue are not compliant to what the standard mandates. Regarding the IMSI disclosure, we want to emphasize the fact that this is not the typical

IMSI Catching problem, in this case the IMSI of a victim gets leaked even if the user as a valid temporary identifier, without any attacker's intervention. IMEI plaintext disclosure, even if accepted by the standard [27], should be avoided since it can be used to leak the location of a mobile user. Beyond what we described before, we also tested for *Crypto parameters predictability and correctness*. In other words, we check if the parameters used to setup the cryptography functions are correct (i.e. Authentication and Key Agreement IVs and computation) and well implemented. Among all operators, the challenges shared during AKA do not show any particular correlation with one another and the randomness of the RAND (used as IV), without any deep analysis, seems solid. To further validate such values, an in-depth study on the reported values is necessary, but this study is out of goals predetermined for this work. Moreover, to assess whether the *RandomValue* given by the UE during the *Contention Resolution* somehow influences the randomness of the Crypto parameter (like IVs), we forced that value to be fixed among all the runs.

5.2.3. Potential security issues analysis

For what concerns potential security issue that may lead to a wide attack surface, we added extra tests that spoof outbound messages and verify if certain security check are correctly implemented. Through the analysis of multiple registration, we obtained the following information:

Sequence number handling on data plane:

- When the UE exchanges a data PDU, such as for HTTP traffic, the eNB or gNB generates encryption and integrity stream keys using its internal counter, rather than relying on the sequence number provided by the UE. This mechanism ensures proper handling of sequence numbers by the network and prevents spoofing attempts that could lead to Message Replay attacks.

Capabilities downgrade attacks:

- The security capabilities exchanged by the user are always authenticated. There is no trivial way to bypass such mechanism. Moreover, trying to spoof the security capabilities authentication results in the eNB detecting the manipulation and interrupting the communication.

5.2.4. Radio configuration assessment

To assess the radio configuration variations, and consequently the unpredictability, 5GMap gathers two specific messages: **RRC Connection Setup** and **RRC Reconfiguration**. Given those two messages, we did the following analysis on **Radio Configuration features and predictability**:

- Differences in radio configuration between *RRC Setup* and *RRC Reconfiguration*[11]
- Differences among radio configuration exchanged by the same cell during multiple registrations
- Differences among radio configuration exchanged by different cells

In this section, only a summary of the observed results will be presented. The findings are the following:

Differences between RRC Setup and RRC Reconfiguration: when searching for differences between the radio configuration of RRC Setup against the radio configuration of RRC Reconfiguration, the patterns that emerged, for all operators, are the following:

- The radio configuration before the reconfiguration is very similar to the one after the configuration.
- The configuration is not influenced by a registration with or without previous existing context. (i.e. registering with IMSI or TMSI).
- the NR configuration that the network sends is always the same.
- the SRI is always sent in the RRC Setup, in plaintext, and very rarely updated in the RRC Reconfiguration (3 times out of 194 successful registrations). This may lead to an attacker that is persistently able to pinpoint in the radio spectrum the data sent by the user to network.

Differences among various RRC Reconfiguration of the same cell: while comparing different RRC Reconfiguration registered from the same cells, we observed that, beside some minor configuration, each radio configuration was always the same. The only difference noted has been found in the CQI Report Index and in the Sounding Reference Signal Index (when such configurations were available). All the other parameters (i.e. SRB1/SRB2/DRB configuration, physical configuration, transmission modes, NR cell configuration, etc.) remained the same across all the RRC Reconfiguration registered. The only two instances where the RRC Reconfiguration was completely the same across all RRC Reconfiguration was with operators MNO4 and MVNO2. The reason why they differ from the other operators is because both operators do not offer neither CQI and SRS.

Differences among radio configuration of different operators: unlike the other comparisons, in this case, no particular pattern emerged. While previous analyses revealed distinct trends and correlations, this specific examination showed that there is no "preferred" configuration among all the operators. There are some radio configuration that resulted more common among different cells, but since there is no recurring pattern, we cannot draw conclusions. Probably the radio configuration is influenced by internal scheduling policies and load balancing, thus different cells (with different load) may have different radio configuration.

5.2.5. Other findings

5GMap is not limited to acquire only security related aspects of the network, other results that do not directly correlate to security configuration have been gathered during our experiments, in addition to the initial objectives. Such result may not directly affect the level of security that a network offers, but are still valuable to understand how different networks behave and to make a more complete "Map" of the network under test, and more importantly, those discoveries enable the possibility of "clustering" different implementation from various manufacturer. The discovery we made are the following:

The 5G icon, showed in many user handset, does not always mean we have a 5G link. The reason behind this is that a specific value, sent in the SIB2, will determine if the mobile phone shows a 5G icon or not. Theoretically, a Base Station that is not enabled for 5G NSA but only 4G, if that specific flag is present, the UE will show the 5G icon regardless.

Some networks ask the UE to reconfigure its channel as 5G NSA, but the UE registering the network has no subscriber plan for 5G but only 4G.

MME is not fixed, but during our test we observed how, even if connecting to the same cell, the MME Code would sometimes change. This is probably because of internal scheduling policies.

Different Reject causes: when the network determines that the UE trying to register is "unfit" (i.e. some parameters are not allowed), the network detaches the UE. In some instances, the network just signals to the UE to release the radio bearers, in other instances instead the network responds with an Attach Reject. The Attach Reject contains the *cause* of the rejection, which is encoded with a simple number that represents the reason of the detaching. Such causes, more often than not, are not related to the specific issue that denied the establishment of the

[11] Each new radio configuration that the user receives does not overwrite the previous one, instead, after the first "RRC Setup" message, the subsequent messages that contains radio configuration (i.e. RRC Reconfiguration) notify the user of "changes".

connection and give a very "broad" range of possible interpretation to what may have gone wrong during the registration procedure. During our tests we distinguished four behavior that the networks showed:

- *RRC Release:* without giving any extra information, the network instructs the UE to release the radio connection.
- *Attach Reject with cause "7":* the networks instruct the UE to detach from the network with the cause "EPS Service not allowed".
- *Attach Reject with cause "13":* the networks instruct the UE to detach from the network with the cause "Roaming not allowed in this tracking area".
- *Attach Reject with cause "14":* the networks instruct the UE to detach from the network with the cause "EPS Service not allowed in this PLMN".

As it can be easily deducted, none of the four behavior observed can be correlated to the tests we conducted. As a consequences, there is no clear explanation of why the network determined that the UE is not allowed to access to mobile services.

Access Point Name requirements: The Access Point Name is a gateway between a mobile network and another network, typically the public Internet or a private network. In commercial networks, a valid APN is necessary to access IP services or IMS calling from a cellular connectivity [29]. During the registration procedure, we observed that the majority of networks/operators required a fixed Access Point Name (APN) that corresponds to the operator for successfully establishing a PDN Session, while with a minority of networks, we were able to successfully register without providing an APN.

Establishment Cause: when a User Equipment registers to the networks, it communicates the reason why it requires cellular connectivity [30]. While there are Establishment causes for specific scenarios, the typical ones are *Mobile-Originating Signaling (MO-Signaling)* and *Mobile-Originating Data (MO-Data)*. Those two are respectively used for when the UE needs to open a connection to send "Signaling" PDUs (i.e. Session management, mobility, etc.) and when the UE needs a PDN session for exchanging Data traffic (i.e. IP services, calls, etc.). We observed that the networks will not allow us to establish a connection when registering with *MO-Data*, while it was possible to have a full PDN Session when giving the establishment cause of *MO-Signaling*. This behavior, shared among all the tested networks, does not properly comply to what the standard states. Moreover, we observed that all of the commercial UEs we analyzed, they never provide the cause of *MO-Data* but always use *MO-Signaling*, even in the instances were the UE was trying to establish a connection to have internet access (which should be signaled using the MO-Data cause).

Registration Procedure Variation: During the registration procedure (i.e. Attach Request) among the tested networks, we observed variation in which messages were exchanged. In particular, the differences resides in the exchange of the following control messages:

- **Exch.1** — *ESM Information Request & Response*: After the *Security Mode Command*, some networks send to the UE a "ESM Information Request", which is messages used to ask the UE his desired PDN configuration (i.e. the APN). Consequently, the UE responds to this message with a "ESM Information Response" with the desired information requested by the network.
- **Exch.2** — *EMM Information*: At the end of the Attach Procedure (after the Attach Complete sent by the UE), the network sends an "EMM Information" message that contains some extra information that might be useful to the UE. The most notable information sent within this message is the *Date Time* (with the relative Time Zone expressed in UTC Format) and the suggested *DNS Server* to be used for DNS Queries.

Among the 7 networks we tested, we observed no predominant pattern. Some networks exchanged only **Exch.1**, others only **Exch.2**, some both **Exch.1** and **Exch.2**, and the remaining networks exchanged neither.

PDCP Discard Timer: another configuration we observed among all operators, that may be problematic under certain circumstances, is the **PDCP Discard timer**. This timer describes the time period that a User Equipment shall store a PDCP message if it cannot be sent (i.e. Radio-level problem or Handover procedure). This means that if the UE is never able to send that PDU, it may store it indefinitely. The PDCP Discard Timer is introduced exactly to avoid such behavior and discard the unsent PDU after a time period, chosen by the network. The issue we found in this parameter is that all the networks we tested demand the user to have a **Infinite Discard Timer**, which means that the PDU, if the UE is not able to send it, will be kept indefinitely. This configuration can be somewhat exploited and force the UE to keep all the outbound PDUs and eventually fill the memory of the device, thus opening the UE to many vulnerable scenarios.

Measurement report for 5G NSA: some networks offer the 5G connectivity by just checking if the UE is capable of performing such connection, while other networks required a *Measurement Report*: the UE needs to send a report of the signal level perceived from the gNB before the network instructs the UE to enable the dual connectivity.

6. Discussion

In this paragraph, we briefly discuss the obtained results with their respective main implications and extra consideration with information about the tested network that contribute to a deeper understanding of their implementation choices.

While the majority of the issues found in this research can be categorized as misconfigurations, other flaws are instead related to implementation errors and oversight in the standard. As an example, disclosing the IMEI in the Security Mode Complete, which is authenticated and not encrypted, can lead to a series of privacy compromises and should be fixed in future release of the standard. When the user is already identified through TMSI, IMSI exposure with an Identity Request can be classified instead as implementation flaw and should be fixed by network manufacturer in future updates.

The experiments we conducted target only a small portion of the Italian territory, which may be not representative of the overall situation in Italy and in other regions. Nonetheless, while some finding are purely configuration related (i.e. supported encryption/integrity algorithms), and may vary among different operators, other finding are more related to the implementation of the network itself. It is safe to assume that the networks made from the same manufacturer, even if used in different regions and by different MNO, will exhibit the same behavior reported in this article.

Regarding radio configuration, we found that it is fairly easy to predict the radio configuration of a 4G/5G NSA connection for each user of the network.

The physical configuration of the radio most of the times does not change between the first configuration (sent unencrypted) in the RRC Setup and the following reconfigurations (sent encrypted) signaled with RRC Reconfiguration messages. In the instances where we observed a variation, it regarded some logical configurations that do not alter the way data is exchanged between the UE and the network. Such logical configurations are easily predictable since we observed that they are the same across multiple registration and users, so acquiring those configuration can be as trivial as connecting to the network with a legitimate user and store such parameters.

There are two physical parameters that are relevant in order to fully synchronize with a radio bearer of a specific user: *Scheduling Request Index* and the *Transmission Mode*. From our experiments we observed that the former parameter is sent during the channel configuration in the RRC Setup (sent unencrypted) and it does not vary in the

subsequent reconfiguration, so it is trivial to obtain this parameter; instead the latter parameter, even if it cannot be obtained by directly listening the radio communication of a user,[12] it can be predicted since it is the same for every user.

The implication of the aspect discussed the possibility to passively acquire the radio spectrum and efficiently track a user without the need of conjectures or "brute-forcing" certain parameters. Another implication is that an active attacker can effectively employ a Man in the Middle attack and provide a radio connectivity that is configured the same way as the legit network. By itself, the possibility of sniffing user traffic or acting as Man in the Middle does not hinder the security of the network and its users, but combined with other vulnerabilities can pose a serious threat.

It has been observed that to obtain a complete mapping of all algorithms supported by only the Base Station, it is necessary to perform the attach only with the TMSI. However, regarding a complete mapping of the algorithms supported by the Core Network, it is necessary to perform the attach only with the IMSI. The result of this is that the registration with TMSI, which should not change the level of security, in the observed networks consistently reduced the level of security protection offered.

Further efforts were made to send attach requests without integrity protection in TMSI-based connections. However, it was noted that the Core Network initiates AKA (Authentication and Key Agreement) to authenticate the device and initialize security protocols, mirroring the process when attaching with IMSI. Consequently, an approach for attaching without NAS-level integrity and perform downgrade attacks remains elusive.

The typical process of security assessment using a *black box paradigm* involves analyzing the limited clues provided by the System Under Test (SUT). Unlike other technology stacks, mobile networking offers minimal information through protocol messages. This lack of transparency is due to both the standard developers and network component manufacturers. The absence of detailed outputs in 4G/5G specifications makes security assessment a more arduous and lengthy process, often involving *unnecessary* "trials and errors" and conjectures, leading to uncertainty about the inner workings of mobile networks.

While the 3GPP standard is detailed in many aspects of the technology, it often lacks precise guidelines on certain details, leaving some aspects up to implementation. Manufacturers may choose not to fully adhere to the standard, and the unspecified details in the standard documentation are implemented according to each manufacturer's preferences. This dynamic results in having networks that differ significantly in behavior and interaction compared to each other.

6.1. Potential countermeasures

To address vulnerabilities related to mobile network security, it is essential to implement a set of countermeasures that ensure the protection of communications and user privacy. First, it is crucial to configure networks to completely disable the use of EEA0 and EIA0 as negotiable algorithms after security activation in standard connection scenarios (i.e. non-emergency). This ensures that the communication between the UE and the network cannot be tampered and/or intercepted, with the result of reduced risk of attacks and compromises. Another fundamental measure is to use algorithms for generating TMSI that employ high entropy sources, ensuring that TMSIs are random and unpredictable, thereby helping to prevent impersonation attempts and pattern analysis attacks. It is also important to establish policies that require the TMSI to be changed for each new attach session or at regular intervals, further reducing the likelihood of impersonation attacks and enhancing the overall security of communications. This particular aspect has been improved in 5G technology, requiring mandatory updates of TMSI value after each attach attempt. Furthermore, it is advisable not to request the IMSI and IMEI when the attach is executed with the TMSI, as the security context has already been established. There is no need for further user identification, particularly through plain-text exchanges. It is also crucial to ensure integrity protection in the NR channel, in compliance with standard recommendations.

Regarding the predictability of radio configurations, even if not a primary security concern, further efforts can be made to partially masquerade which radio bearer correspond to which user by easily refreshing the SRI during the RRC Reconfiguration. In 5G there are already countermeasures to this type of issue: the **Scrambling Code** has been introduced to make control information (i.e. Downlink Control Information) inaccessible to other users beside the addressed one [31].

7. Related work

Since the advent of LTE and the rise of 5G, research into the security of cellular network protocols has significantly increased. Formal methods have been employed to rigorously analyze the security and privacy of 4G and 5G protocols, ensuring thorough verification and validation. These methods often reveal potentially exploitable vulnerabilities. For example, the recent demonstration of user tracking capabilities despite 5G's IMSI encryption, as shown in [32], builds on a linkability issue first identified by [33] through the formal analysis of the 5G-AKA protocol.

On the other hand, implementations inherently expand the range of potential threats, necessitating practical methods like fuzzing [34] to identify vulnerabilities. Fuzzing techniques tailored for 5G systems must generate data patterns and protocol messages specific to 5G protocols [35–37]. Additionally, because access to source code is often limited, these fuzzing methods need to be designed as black-box tests, capable of operating remotely or even through the air interface [38,39].

In contrast to the aforementioned methods, our approach is orthogonal, offering a tool that comprehensively examines supported cipher-suites, default configurations, and overall security measures. Our goal is to identify (mis-)configuration issues and evaluate general security rather than focusing on design or implementation flaws.

When it comes to testing methodology, certain tasks may require specific roles. For example, performing many of the 3GPP standard Security Assurance (SCAS) tests necessitates direct access to the network function being examined. This access is only possible within the core network infrastructure itself or within an appropriate replica on a testing platform [40].

Conversely, testing User Equipment (UE) "simply" involves programming an appropriate "fake" base station to which the UEs can connect. These UEs are then exposed to spoofed protocol messages to observe their reactions [41,42].

Our idea of checking security algorithms support is close to [43], but our approach differs in three key aspects. Firstly, our implementation choices and tools differ significantly.[13] Secondly, our goal is to comprehensively explore and document the entire configuration space. This involves mapping all algorithms supported by networks and identifying their default usage in both the Access Spectrum and Non-Access Spectrum, rather than simply verifying the network's support for "null" encryption/integrity. Thirdly, and perhaps most importantly, 5GMap is meticulously crafted to extract a comprehensive array of parameters and configurations exchanged between UE and Base Stations or the Core Network, not only the possibility of connecting without encryption and integrity. Moreover, our testing with 5GMap spans across both LTE and 5G-NSA networks, showcasing its versatility and capability across different generations of mobile networks.

[12] While some operator send this value in plaintext and does not change in the subsequent reconfiguration, other operators send it in both the radio configuration.

[13] One reason for this is that we were unfortunately unaware of this work when we began developing 5GMap.

Some studies, such as those by [44], have found that the TMSI is not updated in LTE, or even if it is, the reassignment logic follows a sequential pattern [45]. Unlike our study, however, these studies were conducted by analyzing the paging channel. In contrast, we analyze the responses of Core Networks when they assign a new TMSI to the UE.

To our knowledge, there is no such tool, publicly available, that is able to extrapolate this type of data from a legitimate 4G/5G NSA network by interacting with it as a common User Equipment. Smartphones and other kind of UEs, even if theoretically capable of conducting such experiments, modem manufacturer deny the end user for this type of interaction with the network stack and do not offer any pre-defined test suite that can even partially inform the user of the security of the network they are connected to.

8. Conclusions

This work aims to empower users by providing means to gain comprehensive visibility and a deeper understanding of 4G and 5G access security configurations. Indeed, the experimental results gathered from seven mobile network operators, including three virtual operators, provide clear evidence of numerous security and privacy concerns. Many networks still allow unencrypted and unauthenticated communication, and features like identifier concealment and temporary address randomization are inconsistently implemented, leading to potential privacy issues such as user tracking. Additionally, implementation and configuration flaws can be exploited to force unsecured radio channels, making it easy to track users, eavesdrop, or conduct attacks. Connecting with a TMSI can bypass certain security measures. Furthermore, the upgrade to 5G often fails to improve security due to missing data integrity.

We believe that our tool's ability to identify network security issues from the end-user perspective, traditionally managed exclusively by operators, has the potential to enhance network security through increased community involvement. In other words, our work serves not only as a survey of issues in modern cellular networks but also as a call to action for mobile network manufacturers and the 3GPP. It advocates for a more open approach, leveraging the cybersecurity community's expertise to improve the overall security of these services.

While our tool is already capable to identify several vulnerabilities in commercial deployments,[14] many aspects remain unexplored, and we believe a more in-depth study of these networks could reveal even more critical implementation errors that may compromise 4G and 5G security.

CRediT authorship contribution statement

Andrea Paci: Methodology, Data curation. **Matteo Chiacchia:** Software, Methodology. **Giuseppe Bianchi:** Conceptualization.

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Acknowledgments

This work was partially supported by the rEU under the Italian National Recovery and Resilience Plan (NRRP) of NextGenerationEU, partnership "Telecommunications of the Future" (PE00000001 - program "RESTART") and "SEcurity and RIghts In the CyberSpace" (PE00000014 - program "SERICS").

[14] Responsible disclosure has been issued to affected operators, and one operator has already fixed some reported misconfigurations.

Data availability

The data that has been used is confidential.

References

[1] C. Yu, S. Chen, F. Wang, Z. Wei, Improving 4G/5G air interface security: A survey of existing attacks on different LTE layers, Comput. Netw. 201 (2021) 108532, http://dx.doi.org/10.1016/j.comnet.2021.108532.
[2] B. Karakoc, N. Fürste, D. Rupprecht, K. Kohls, Never let me down again: Bidding-down attacks and mitigations in 5G and 4G, WiSec '23, 2023, pp. 97–108.
[3] R. Zhang, W. Zhou, H. Hu, Towards 5G security analysis against null security algorithms used in normal communication, Secur. Commun. Netw. 2021 (2021) http://dx.doi.org/10.1155/2021/4498324.
[4] D. Rupprecht, K. Kohls, T. Holz, C. Pöpper, Breaking LTE on layer two, in: 2019 IEEE Symposium on Security and Privacy, SP, IEEE, 2019, pp. 1121–1136.
[5] A. Shaik, R. Borgaonkar, S. Park, J.-P. Seifert, New vulnerabilities in 4G and 5G cellular access network protocols: Exposing device capabilities, WiSec '19, 2019, pp. 221–231.
[6] ENISA, Security in 5G specifications, controls in 3GPP security specifications (5G SA), 2021, (Accessed on 4 November 2023).
[7] A. Paci, M. Chiacchia, G. Bianchi, 5GMap: User-driven audit of access security configurations in cellular networks, 2024, pp. 97–104, http://dx.doi.org/10.23919/WONS60642.2024.10449586.
[8] P. Moorhead, Why 3GPP Just Works – Multiple Generations of Global Cellular Standards and Solid Execution, 2021.
[9] 3GPP, Non-Access-Stratum (NAS) protocol for 5G System, 2018.
[10] 3GPP, Evolved universal terrestrial radio access network (e-UTRAN), S1 application protocol (S1AP), 2014.
[11] 3GPP, Radio resource control (RRC) protocol specification, release 15, 2019.
[12] 3GPP, Packet data convergence protocol (PDCP) specification, release 15, 2018.
[13] 3GPP, Radio link control (RLC) protocol specification, release 15, 2018.
[14] 3GPP, Medium access control (MAC) protocol specification, release 15, 2019.
[15] 3GPP, Security architecture and procedures for 5G system, 2018.
[16] B. David, F. Vincent, How to design a baseband debugger, in: SSTIC 2020, 2020.
[17] E.C. Elejalde, OffensiveCon2022, Building a DIY baseband debugger from scratch, 2022, (Accessed on 26 May 2024).
[18] Ettus Research, USRP B210 Overview, URL https://www.ettus.com/all-products/ub210-kit/, (Accessed on 9 November 2023).
[19] Ludovic Rousseau, pcsc-tools: Tools for testing PC/SC functions of smart cards and readers, URL https://github.com/LudovicRousseau/pcsc-tools, (Accessed on 3 November 3, 2023).
[20] SRS, srsRAN_4G: An Open Source 4G LTE and 5G NR Software Radio Implementation, Accessed: 2023, https://github.com/srsran/srsRAN_4G.
[21] ZeroMQ, URL https://github.com/zeromq, Accessed: 2023.
[22] GitHub - andreapaci/json_parser, URL https://github.com/andreapaci/json_parser, Accessed: 2024.
[23] 3GPP, Non-access-stratum (NAS) protocol for evolved packet system (EPS), Sec. 4.4.4.2, 2022.
[24] QTRUN Technologies, Network signal guru, 2023, URL https://www.qtrun.com/.
[25] GNU Radio, URL https://www.gnuradio.org/, (Accessed on 11 November 2023).
[26] V. Mazalov, A. Lukyanenko, A. Gurtov, Location-price competition in mobile operator market, Int. Game Theory Rev. 21 (2018) http://dx.doi.org/10.1142/S0219198918500159.
[27] 3GPP, 3GPP system architecture evolution (SAE); security architecture, 2024, (Accessed on 5 January 2024).
[28] 3GPP, Security architecture, 2022, (Accessed on 5 January 2024).
[29] 3GPP, Numbering, addressing and identification, 2020, (Accessed on 25 May 2024).
[30] 3GPP, System architecture for the 5G system (5GS), 2020, (Accessed on 27 May 2024).
[31] 3GPP, 5G; NR; physical channels and modulation (3GPP TS 38.211 version 15.2.0 release 15), 2018.
[32] M. Chlosta, D. Rupprecht, C. Pöpper, T. Holz, 5G SUCI-Catchers: Still catching them all? in: Proc. 14th ACM Conf. on Security and Privacy in Wireless and Mobile Networks, 2021, pp. 359–364.
[33] D. Basin, J. Dreier, L. Hirschi, S. Radomirovic, R. Sasse, V. Stettler, A formal analysis of 5G authentication, in: Proceedings of the 2018 ACM SIGSAC Conference on Computer and Communications Security, 2018, pp. 1383–1396.
[34] B. Miller, L. Fredriksen, B. So, An empirical study of the reliability of UNIX utilities, Commun. ACM 33 (1990) 32–44, http://dx.doi.org/10.1145/96267.96279.
[35] D. Rupprecht, K. Jansen, C. Pöpper, Putting LTE security functions to the test: A framework to evaluate implementation correctness, in: 10th USENIX Workshop on Offensive Technologies (WOOT 16), 2016.
[36] I. Karim, S.R. Hussain, E. Bertino, Prochecker: An automated security and privacy analysis framework for 4g LTE protocol implementations, in: 2021 IEEE 41st Int. Conf. on Distributed Computing Systems, ICDCS, IEEE, 2021, pp. 773–785.

[37] C. Park, S. Bae, B. Oh, J. Lee, E. Lee, I. Yun, Y. Kim, DoLTEst: In-depth downlink negative testing framework for LTE devices, in: 31st USENIX Security Symp. (USENIX Security 22), 2022, pp. 1325–1342.

[38] M.E. Garbelini, Z. Shang, S. Chattopadhyay, S. Sun, E. Kurniawan, Towards automated fuzzing of 4G/5G protocol implementations over the air, in: GLOBECOM 2022-2022 IEEE Global Communications Conference, IEEE, 2022, pp. 86–92.

[39] H. Wang, B. Cui, W. Yang, J. Cui, L. Su, L. Sun, An automated vulnerability detection method for the 5G RRC protocol based on fuzzing, in: 4th Int. Conf. on Advances in Computer Technology, Information Science and Communications, CTISC, IEEE, 2022.

[40] F. Mancini, G. Bianchi, ScasDK-A development kit for security assurance test in multi-network-function 5G, in: Proc. 18th Int. Conf. on Availability, Reliability and Security, 2023, pp. 1–8.

[41] E. Bitsikas, S. Khandker, A. Salous, A. Ranganathan, R. Piqueras Jover, C. Pöpper, UE security reloaded: Developing a 5G standalone user-side security testing framework, in: Proc. 16th ACM Conf. on Security and Privacy in Wireless and Mobile Networks, 2023, pp. 121–132.

[42] C. Yu, S. Chen, Z. Wei, F. Wang, SecChecker: Inspecting the security implementation of 5G commercial off-the-shelf (COTS) mobile devices, Comput. Secur. (2023) 103361.

[43] M. Chlosta, D. Rupprecht, T. Holz, C. Pöpper, LTE security disabled: Misconfiguration in commercial networks, in: Proc. 12th Conf. on Security and Privacy in Wireless and Mobile Networks, 2019, pp. 261–266.

[44] A. Shaik, R. Borgaonkar, N. Asokan, V. Niemi, J.-P. Seifert, Practical Attacks Against Privacy and Availability in 4G/LTE Mobile Communication Systems, 2016, http://dx.doi.org/10.14722/ndss.2016.23236.

[45] B. Hong, S. Bae, Y. Kim, GUTI Reallocation Demystified: Cellular Location Tracking with Changing Temporary Identifier, 2018, http://dx.doi.org/10.14722/ndss.2018.23365.